

Executive Report

Incident Summary

A Linux workstation was compromised following a successful SSH brute-force attack against a valid user account: the telemetry indicates 208 failed SSH attempts within 57 seconds. The attacker escalated privileges, established persistence, and accessed sensitive HR data affecting up to 126 current and former employees. Approximately 10MB of data was exfiltrated over HTTP. The incident was detected through SIEM monitoring and has been fully contained, eradicated, and recovered.

Timeline

18:12 Reconnaissance activity detected
18:19 Initial access achieved through SSH brute force
18:20 Incident detected and investigation initiated
19:10 Containment completed
19:22 Eradication completed
19:48 Recovery completed

Impact Assessment

- Confidentiality: confidentiality was compromised through sensitive data exfiltration
- Integrity: system integrity was compromised through unauthorized configuration and persistence changes
- Availability: no evidence of service disruption
- Affected assets: 1 Linux workstation
- Affected identities: 1 compromised account
- Potentially affected individuals: up to 126 employees
- Sensitive information: personal identity information, banking information, salary information, credential hashes

Actions taken

Detection & Investigation

- Identified suspicious sessions and active network connections.
- Investigated user accounts for persistence mechanisms.
- Identified malicious scheduled task and unauthorized SSH keys.

Containment

- Terminated suspicious sessions.
- Disabled the compromised account.
- Blocked the attacker's IP.

Eradication & Recovery

- Removed persistence mechanisms.
- Rotated exposed secrets and regenerated SSH keys.

- Disabled the vulnerable SUID configuration.
- Restored the affected workstation.

Key Findings

The attack used the following techniques:

- **Reconnaissance:** host and port scan
- **Initial access:** successful brute-force on a discovered SSH account
- **Discovery:** commands on the endpoint
- **Privilege escalation:** abusing a SUID-enabled binary
- **Persistence:** creating a malicious scheduled job and adding an SSH key-based access
- **Collection:** looking for sensitive data and gathering files
- **Exfiltration:** sending the collected data over HTTP traffic
- **Defense evasion:** removing traces of the attack from the shell history

The detailed evidence of each step is available in the investigation report.

Root Causes & Contributing factors

- Weak password used for an SSH account
- Exposed username in service banner
- Excessive risk associated with a SUID-enabled binary
- Sensitive cleartext data storage

Lessons learned

Findings	Recommendation
SSH key-based authentication and access creation is not detected	Add a Sigma rule to detect SSH key-based authentication and access creation
SUID abuse was not detected	Monitor SUID binaries based on the known exploitable list of binaries
Sensitive cleartext HR data is accessible	Apply the least privileges policy and encrypt sensitive data at rest
Weak user credentials and username exposure facilitate the attack	Run a security awareness training, implement multi-factor authentication